
Falcon Junior School Audit Report**Audit Date: 10/10/19****Report: Year 2 visit 1****DPE: Stuart Lee****School member: Rob Clarke**

1. Visit details

The school have already been proactive with their GDPR project. Rob has a working spreadsheet that has formed the main action plan and will carry on with this method. Rob also has the option of using the DPE online best practice tick lists. DPE best practice areas, compliance checklists, SLAs and compliance manager discussed/demonstrated with the school. Recommended the school complete the compliance checklist initially. Kalina (DPE) had already completed a remote session, with another session to be planned in the future.

2. Audit walk findings

Good practice was observed again during the walk; confidential waste bins; forename only on lists and display; printers have codes; all laptops are encrypted; offices have secure key fob entry; office areas were clear and tidy and when discussing with staff during the walk, staff were aware of their responsibilities. We discussed that the school were now at the stage of 'telling' to 'staff doing'. Rob had already completed internal walks and fed back findings to staff. Comments from the visit walk are detailed below:

- **Classrooms** – there was a general lack of storage in each classroom. Suggested the school could complete a reshuffle to allow placing of confidential/sensitive data into cabinets rather than being on general display (i.e. steps to success folders);
- **Unlocked laptops:** Reminder to staff to lock laptops when not present;
- **Staffroom** – care plans/medical information on staff information board (covered/reversed): School has reviewed with risks to data and health and welfare of the child. From the review the school consider it essential that this information is accessible and not locked away. School confirmed that the staff room has limited entry and is locked at night. Discussed other options available i.e. folder systems. School will keep to current practice and regularly review.
- **Displays with photo and names** – school to revisit against DPE consent guidelines to ensure consent aligns with data on display.

The school can introduce the best practice guide which can be displayed and used to support raising staff awareness:

<https://kb.dataprotection.education/best-practice-library/documents/drip-feeds/57-dpe-quick-reference-guide>

End of day check list for teachers was discussed and deemed a good idea (best practice guide can support this).

3. Compliance actions that should now be completed

Initial documents:

- **Privacy Notice**
- **GDPR Policy**
- **Data Breach Procedure**
- **SAR procedure**
- **Photo and Video consent, guidelines and records**

Ideally you would also have: Work away from school, clear desk and screen, information classification and record management policy/paperwork. Schools have either adopted the DPE models or incorporated some of this within their staff handbook, for example, work away from school.

The following should also be completed:

- There should be no named person on any of the above documents. If there is a named person i.e. Stuart Lee, the name needs replacing with: Data Protection Education Ltd;
- The Privacy Notice should have an appendix with your third-party suppliers listed. If using GDPRiS this should also be kept updated. You should also make sure suppliers are GDPR compliant;
- The Privacy Notice, GDPR Policy and consent withdrawal form should be displayed on the school website;
- All staff should know what the data procedure is, and the document should be circulated to all staff;
- Key staff responding to SARs should have access to the SAR procedure and understand their responsibilities.

3.1. Data retention schedule:

By now you should be working through both physical and electronic data and have a good understanding of what data you hold and be documenting this. There are a number of documents available to support the process:

- Governor hub: annual review of school data and safe data destruction checklist
- IRMS toolkit: https://c.ymcdn.com/sites/irms.site-ym.com/resource/collection/8BCEF755-0353-4F66-9877-CCDA4BFEEAC4/2016_IRMS_Toolkit_for_Schools_v5_Master.pdf
- DfE toolkit
https://assets.publishing.service.gov.uk/government/uploads/system/uploads/attachment_data/file/747620/Data_Protection_Toolkit_for_Schools_OpenBeta.pdf (Annex 5,1)

3.2. Staff training

GDPR training should be completed and documented. If not already you should:

- Rollout training to key staff and then consider all staff completing the e-learning training;
- Add as part of the induction process for new staff;
- Use staff meetings/briefings to raise staff awareness.

3.3. Governance check

It should form part of governance that GDPR is an item at governor meetings and to share reports with governors. Ideally the governor responsible for GDPR will have completed some form of GDPR training.

3.4. Make sure DPE is your registered DPO with the ICO

Not only do you need to be registered as a controller with the ICO, it is a requirement to register who your DPO is. The guide to complete this is available from the News section of the DPE website: <https://kb.dataprotection.education/news-top/news/83-best-practice-updates/110-make-sure-dpe-is-your-registered-dpo-with-the-ico>

4. Freedom of Information and Publication Scheme

The DPE GDPR policy and FOI policy content refer to the organisation having a publication scheme - do you have one? **The template for a model publication scheme can be obtained from:** <https://ico.org.uk/media/for-organisations/documents/1235/definition-document-schools-in-england.pdf> How to complete a publication scheme guide can be obtained from: <https://ico.org.uk/media/for-organisations/documents/1242/how-to-complete-template-guide-to-info-for-schools.pdf> Additional guidance can be obtained from the news section of the DPE website: <https://kb.dataprotection.education/news-top/news>

5. Technical measures

DPE recommends schools complete the Cyber essentials questionnaire available from: DPE>Resources> Information Technology Security: <https://kb.dataprotection.education/best-practice-library/documents/information-technology-security/7-crest-cyber-essentials-questionnaire>;

Check iPad/Tablet security. Are all laptops encrypted, does your end of day routines include housekeeping to remove data no longer needed and is equipment secured? Do staff still use unencrypted memory sticks? DPE recommends schools develop procedures to ensure iPads can be accounted for daily and data (i.e photos) can be cleared if lost or stolen ([Erase your device](#))

6. Next steps

Record of Processing (RoP) tool and data mapping

DPE have started to populate the Record of Processing (RoP) tool. Rather than each school complete individually, DPE will be populating as many processes as possible and then work with you to complete for your school. It is a requirement under article 30 of the GDPR and will form part of the basis for future remote sessions and visits.

6.1. Data Protection Impact Assessments (DPIA)

When processing high risk personal data and using new technologies (i.e. moving to a new technology for Safeguarding) a DPIA should be completed and the DPO consulted (Article 35.2). DPIAs offer a risk assessment template where concerns can be noted alongside mitigating actions to reduce the overall risks related to change of practice. It is good practice to complete a DPIA for any major project where the processing of personal data is required. DPE will be providing more guidance, training and include risk management within the RoP tool. Always contact DPE in the first instance.

7. Norfolk County Council Summer GDPR audits

NCC auditors completed several themed GDPR audits during the summer term 2019. DPE have provided feedback to the findings which can be obtained from the News section of the DPE website: <https://kb.dataprotection.education/news-top/news>